PaperFlow

Code audit, security hardening and dark mode

Report on the changes made to the PaperFlow application: what was changed, why it was changed, and how each change was verified.

Date	16 October 2026
Repository	PaperFlow (branch `main`, base commit 4f52652)
Prepared for	Sanskar
Prepared by	Claude (Anthropic), working in Claude Code
Status	Merged to main

1. Executive summary

> The application was audited end to end, with particular attention to tenancy and the service-role key. One high-severity issue was found and fixed (an institute admin could reset the password of a person who also belongs to another institute, including the platform owner), together with an open redirect on sign-in and several lower-severity weaknesses. The test suite now passes in full: 450 of 450 tests, against 293 passing before, when ten database suites failed on a setup timeout. The original design was kept. An opt-in dark mode was added on top of it, and explanatory copy was cut back across every role. The teacher and student workflows were exercised live against the development database, and both work end to end.

7	**450 / 450**	**+24**	**0**
security issues fixed (1 high, 1 medium, 5 low or hardening)	tests passing (was 293 passing, 10 suites failing)	new tests (security, password guard, theme)	fonts downloaded twice (Inter and Devanagari were)

2. Scope and method

- **Code audit.** Every server action, route handler and middleware path was reviewed, as was every use of the service-role client. HTML sinks (`dangerouslySetInnerHTML`) were traced to their sources, and redirect handling and file uploads were reviewed. The review was carried out against the project rules in `CLAUDE.md` .
- **Dead-code sweep.** A scripted search was run for exports referenced nowhere else and for CSS classes used by no component.
- **Design references.** Two published guidelines were researched and applied:
  - Anthropic's *frontend-design* skill: typography, colour, motion and layout discipline, and a list of patterns to avoid.
  - Vercel's *Web Interface Guidelines*: accessibility, focus states, forms, animation and content handling.

  Neither adds any runtime code to the site.
- **Live walkthrough.** The teacher and student workflows were run in the browser against the development database, in light and dark mode, at phone and desktop widths. The institute-admin and platform-owner consoles were reviewed in code: they use the same shared frame and components, but no session for those roles was available.
- **Verification.** TypeScript strict typecheck, ESLint, the full Vitest suite (including the PGlite database harness) and a production build were run after the changes.

3. Security findings and fixes

Severity	Finding	Change made	Verification

High	**Cross-tenant account takeover through password reset.** An institute admin could issue a temporary password for any teacher or student of their institute, even if that person also belonged to another institute. That included the platform owner, if they held a seat there. A password opens the whole account, so one tenant's admin could take over access to another tenant.	New `belongsOnlyTo()` in `src/server/passwords.ts`. A reset is refused unless every membership the person holds is in the admin's own institute. The check reads with the service role and is pinned to an institute predicate. If the check fails it refuses, rather than allowing the reset.	5 unit tests: single-institute (allowed), two institutes, platform owner, unrelated rows, read failure.
Medium	**Open redirect after sign-in.** The `?next=` check accepted `/\evil.example`. Browsers read the backslash as a slash, so the sign-in form would send the user to another site.	New shared `safeNextPath()` (`src/lib/safe-redirect.ts`). It rejects `//`, backslashes and control characters. Both the sign-in form and the OAuth callback now use it.	5 tests, including a check that every accepted value stays on the origin.
Low	**Figure uploads trusted the browser's MIME type.**	The file's own signature is now checked (PNG, JPEG or WebP magic bytes) before it is stored (`src/lib/image-sniff.ts`).	2 tests, including HTML, SVG and WAV disguised as images.
Low	**Institute export route:** a malformed or `null` Origin header made the CSRF check throw, and internal database errors were returned to the browser.	`isSameOrigin()` (`src/lib/same-origin.ts`) parses the header safely. Error details now go to the server log; the user sees a plain message.	2 tests.
Low	**Math rendering limits.** Question text is rendered with KaTeX. Safe defaults were relied on implicitly, and a macro expansion could be made very expensive.	`trust: false` is now explicit, and expansion and size limits are set in `src/lib/print/math.ts`.	3 tests: HTML escaping, `\href` / `\url` neutralised, macro bomb bounded.
Low	**Service-role query without a tenant predicate** on the platform Questions page, which breaks the project rule.	The page list and the answer lookup are both pinned to the shared-bank institute.	Typecheck and build.
Hardening	No baseline security headers were set.	`X-Frame-Options`, `X-Content-Type-Options`, `Referrer-Policy` and `Permissions-Policy` are now set on every response (`next.config.ts`).	Production build.

Reviewed and left as is: account creation has a honeypot but no rate limit (see recommendations). The platform audit CSV returns database error text, but only to the platform owner. Everything else reviewed was found correct: role checks in every action, institute resolved from the session only, solutions released only through the attempt gate, and service-role use pinned to institutes.

4. Reliability, tests and efficiency

4.1 Test suite

- **Fixed:** ten database suites failed on every full run with "Hook timed out in 10000ms". Each suite boots its own PGlite and replays all migrations; run in parallel, that can take longer than 10 seconds. Each suite passed when run alone. The hook timeout is now 120 seconds (`vitest.config.ts`). Result: 39 of 39 files and 450 of 450 tests pass. Before the change, 293 passed and 133 were skipped because their suites failed.
- **Added:**

- `tests/app/security.test.ts` (12 tests).
- The password-reset guard tests in `tests/app/passwords.test.ts` (5).
- `tests/app/theme.test.ts` (7). These guard the theme: dark mode must redefine every colour token, light must stay the default, every token used must be defined, and no stylesheet rule may use a literal colour. The last guard caught real regressions during this work.

4.2 Performance

- **Duplicate font downloads removed.** Inter was declared twice and Noto Sans Devanagari was declared twice, so each was shipped twice. The Devanagari family (four weights) was also preloaded on every page. All fonts are now declared once in `src/lib/fonts.ts`. Devanagari and the print serif now load only when a page uses them.
- **No new runtime dependencies.** Dark mode adds one 200-byte inline script and one small client component.

4.3 Code clean-up

- Removed unused code: `requireSession()`, `roleAt()`, and the unused CSS rules `.whoinst` and `.laysum*`.
- Removed the last `transition: all`. Fixed an accessibility lint warning on the dropdown (it now uses the ARIA 1.2 select-only combobox role). Removed a stale lint directive. Lint now reports zero warnings.
- Every new module and non-obvious rule carries a comment explaining why it exists, in the style of the surrounding code.

5. Interface and dark mode

The original design is unchanged. A full visual redesign was prototyped during this work: a graph-paper page, a teal navigation rail, amber primary buttons and IBM Plex type. You reviewed it and decided the original white design looked more professional, so that redesign was reverted. What remains is invisible in the default view.

Area	Change and reason
Colour tokens	Every colour in the two app stylesheets is now a named token, for example `--paper`, `--ink`, `--pen`, `--hair` and `--wash`. The light values are the original colours. Several near-identical greys (one or two RGB units apart) were merged into one shade each. This is what makes dark mode possible without duplicating every rule.
Dark mode (opt-in)	Choose Light (the default), Dark or Match device. The switch is in every console sidebar, the student sidebar and the landing page header. A device set to dark does *not* turn the site dark unless its owner picks Dark or Match device. The choice is stored per device and applied before the first paint, so there is no flash.
Dark palette	A warm graphite page with surfaces one step lighter and slightly warm text, so it does not glare. The red pen and teal are brightened to keep their contrast. Featured cards get a deep red-ink fill instead of a bright white block. The logo tile gets an outline so it stays visible.
Paper stays paper	Printed papers and answer keys are always black on white. The landing page's sample paper and question figures keep a white background in dark mode.
Guard tests	`tests/app/theme.test.ts` checks four things: dark mode redefines every colour, no stylesheet switches to dark from the device setting alone, every token used is defined, and no rule hard-codes a colour.

6. Copy reduction

Explanatory text that justified design decisions to the user was removed or cut to one actionable line. Examples: "that is deliberate, not a bug", "the app does not pretend", and a three-sentence note on what the logging rate means. Text that tells

someone what to do next was kept.

Role	Screens edited
Student	Tests, logging (set picker, result), practice, weak spots, account, offline banner, welcome and join
Teacher	Batches, set a paper (empty state), paper detail, papers list, results, flagged questions
Institute admin	Members, subjects, teacher subjects, export
Platform owner	Accounts, activation, bank review, institutes and institute detail, support lookup
Public	Landing page (hero, how it works, features, roles, call to action), sign-in panel

Two messages were also factually out of date and were corrected. Both said an invitation is accepted “when they sign in with Google”; username sign-in has been the default since migration 0019.

7. Workflow verification

Role	Workflow exercised live	Result
Teacher	Home → Set a paper: chapters chosen and a preview generated from the live bank. Then Save and print (the paper got code TI-10MAT-261016-01), the print view, the answer key, and Mark as conducted (released to the batch). Batches, Results and Flagged pages also checked.	**Works**
Student	Tests → Start logging → marked questions 1 and 4 wrong → Save. A 4-question practice set was built on the matching topics, and the “needs logging” count dropped. Practice, Weak spots and Account checked, including the theme switch and the subject switcher.	**Works**
Public	Landing, sign-up, print sample, offline page; light and dark; phone and desktop; no horizontal overflow.	**Works**
Institute admin, platform owner	Reviewed in code. These consoles use the same frame, navigation rail and components that were verified above. Their database functions are covered by the database test suites (all passing).	Not run live

Test data created on the development database during verification: the paper “Quick quiz” (TI-10MAT-261016-01) in Testing Institute, batch 10 Maths · Morning, released, and one logged attempt by Test Student with 2 wrong answers. A teacher or institute admin can delete it from the paper’s page by typing its code.

8. Recommendations

- **Retire the `/demo` prototype** (about 40 files). It was last changed on 16 September 2026, predates username sign-in and no longer matches the product. It is already blocked in production.
- **Rate-limit account creation.** Sign-up uses the service role, so Supabase’s own sign-up limits do not apply. A per-IP or database-counted limit, like the existing generation rate limit, would stop bulk sign-ups.
- **Live-check the institute-admin and platform consoles** after review, signed in as those roles.

Appendix A. Files changed

New: src/lib/safe-redirect.ts, src/lib/same-origin.ts, src/lib/image-sniff.ts, src/lib/theme.ts, src/components/ui/ThemeSwitch.tsx, tests/app/security.test.ts, tests/app/theme.test.ts.
Security and server: src/server/passwords.ts, src/server/actions/institute.ts, src/server/actions/platform.ts, src/server/session.ts,

src/server/data/student.ts, src/app/auth/callback/route.ts, src/app/(main)/institute/export/download/route.ts, src/app/(main)/platform/questions/page.tsx, src/lib/print/math.ts, next.config.ts.
Theme and fonts: src/styles/paperflow.css, src/styles/app.css, src/app/globals.css, src/app/layout.tsx, src/lib/fonts.ts, tailwind.config.ts, src/components/brand/Logo.tsx, src/components/ui/Icon.tsx, src/components/ui/Dropdown.tsx, src/app/demo/layout.tsx.
Screens and copy: files under src/app/(main)/ across the student, teacher, institute, platform and welcome areas (copy trims; theme switch placement).
Tooling: vitest.config.ts, tests/app/passwords.test.ts, src/demo/institutes.ts.